Authly

Sistema de Gestión de Accesos

Manual de Usuario

Guía operativa del Panel de Administración Web y referencia de integración

Ingeniería de Software II — UCALP

1. Contenido

El presente manual se organiza en seis secciones principales diseñadas para acompañar al usuario desde el primer contacto con la plataforma hasta la administración cotidiana de sus aplicaciones:

- **1. Contenido:** Presentación general de las partes que integran este documento.
- **2. Índice:** Esquema temático detallado de todos los capítulos, subsecciones y procedimientos incluidos.
- **3. Introducción:** Propósito del manual, descripción funcional de Authly, alcance del producto mínimo viable (MVP) y perfiles de usuario.
- **4. Instrucciones para el uso del manual:** Convenciones tipográficas utilizadas, criterios de búsqueda rápida por tarea y política de actualización del documento.
- **5. Cuerpo principal:** Guía paso a paso para operar el Panel de Administración (registro de organización, inicio y cierre de sesión, recuperación de contraseña, gestión de aplicaciones y credenciales, configuración de roles y permisos, administración de usuarios y funciones transversales de interfaz), junto con una referencia operativa para sistemas externos.
- **6. Anexo o apéndice:** Mapa de navegación entre pantallas, glosario de términos clave y tabla resumen de reglas de validación y seguridad.

2. Índice

Sección	Título del tema	Referencia funcional
Sección 1	Contenido	Estructura documental
Sección 2	Índice	Índice temático
Sección 3	Introducción	Propósito y alcance
Sección 4	Instrucciones para el uso del manual	Convenciones y mantenimiento
Sección 5	Cuerpo principal — Guía operativa del sistema	Operación integral

Sección	Título del tema	Referencia funcional
5.1	Registro de cuenta y organización	AU-CU-01 / `register.html`
5.2	Inicio de sesión, sesión activa y cierre de sesión	AU-CU-02 / `login.html`
5.3	Recuperación de contraseña del administrador	AU-CU-10 / `recovery.html`
5.4	Gestión de aplicaciones y credenciales	AU-CU-03 / `apps.html`, `app.html`
5.5	Gestión de roles y permisos	AU-CU-04 / Pestaña Roles
5.6	Gestión de usuarios de una aplicación	AU-CU-06 / Pestaña Usuarios
5.7	Funciones transversales de la interfaz (tema claro/oscuro y vista móvil)	Interfaz del panel
5.8	Operaciones vía API para Sistemas Externos (referencia rápida)	AU-CU-05, 07, 08, 09, 11
Sección 6	Anexo o apéndice	Material de consulta
Anexo A	Mapa de navegación de pantallas	Flujo de interfaz web
Anexo B	Glosario de términos clave	Definiciones del dominio
Anexo C	Tabla resumen de reglas de validación y límites operativos	AURN-01 a AURN-11

3. Introducción

3.1. Propósito del manual

Este manual tiene como objetivo brindar al **Administrador de Organización** una guía clara, práctica y autosuficiente para operar el Panel de Administración Web de **Authly**. A través de instrucciones paso a paso y descripciones precisas de cada pantalla, el lector podrá registrar su organización, dar de alta las aplicaciones que desea proteger, obtener sus credenciales de integración, definir esquemas de autorización mediante roles y permisos, y controlar el acceso de los usuarios finales.

3.2. Qué es Authly y cómo funciona

Authly es una plataforma centralizada de autenticación y autorización diseñada para que los sistemas consumidores (aplicaciones web, móviles o servicios backend) no deban desarrollar ni mantener mecanismos propios de gestión de cuentas y contraseñas.

La plataforma ofrece dos superficies de trabajo claramente diferenciadas:

- **Panel de Administración Web:** Interfaz gráfica utilizada por el Administrador de cada organización para configurar aplicaciones, roles, permisos y usuarios.
- **API REST Externa:** Conjunto de endpoints estandarizados que los Sistemas Externos consumen en tiempo de ejecución para registrar usuarios finales, autenticarlos mediante tokens firmados (JWT), obtener la clave pública de validación y verificar permisos.

3.3. Alcance del sistema y principios de aislamiento

Para operar Authly con seguridad, conviene tener presentes tres principios fundamentales del producto mínimo viable (MVP):

- **Un Administrador por organización:** Cada organización se identifica mediante un CUIT único de 11 dígitos y cuenta con una única cuenta de Administrador en el MVP.
- **Aislamiento entre aplicaciones:** Cada aplicación posee sus propias credenciales (**Client ID** y **Client Secret**), sus propios roles y sus propios usuarios. Un mismo correo electrónico puede registrarse en distintas aplicaciones de forma independiente, e incluso pertenecer a una cuenta de administrador y a una o varias aplicaciones sin conflicto.
- **Creación de usuarios vía API:** Los usuarios finales nunca se crean manualmente desde el panel web; se dan de alta a través del Sistema Externo conectado a la API y reciben automáticamente el *rol por defecto* configurado para esa aplicación.

4. Instrucciones para el uso del manual

4.1. Convenciones visuales y tipográficas

A lo largo del documento se emplean las siguientes convenciones para facilitar la lectura e identificación de elementos en pantalla:

- **Botones, pestañas y enlaces de acción:** Se destacan en negrita y color institucional, por ejemplo: **«Crear aplicación»**, **«Guardar»** o pestaña **«Roles»**.
- **Archivos o pantallas del panel:** Se indican con tipografía monoespaciada cuando se hace referencia a la ruta o vista activa, por ejemplo: `apps.html`.
- **Mensajes literales del sistema:** Se escriben entre comillas angulares, por ejemplo: «Credenciales inválidas.».
- **Bloques de advertencia:** Señalan acciones irreversibles o condiciones críticas que requieren precaución antes de confirmar una operación.

4.2. Cómo buscar información en este manual

El cuerpo principal (Sección 5) está ordenado cronológicamente según el ciclo de vida de uso de la plataforma: primero el alta y acceso del Administrador (5.1 a 5.3), luego la configuración estructural de aplicaciones y roles (5.4 y 5.5), y finalmente la administración diaria de usuarios (5.6). Si desea consultar una regla puntual sobre formatos permitidos o tiempos de expiración, diríjase directamente al **Anexo C**.

4.3. Actualización y mantenimiento del manual

Este manual refleja las funcionalidades vigentes en el MVP de Authly. Cuando se incorporen nuevas capacidades previstas en el *Product Backlog* del proyecto —tales como invitación de administradores adicionales, filtros de búsqueda en el listado de usuarios, renovación automática de sesión o registro de auditoría—, se actualizarán las subsecciones correspondientes de la Sección 5 y los cuadros del Anexo.

5. Cuerpo principal — Guía operativa del sistema

5.1. Registro de cuenta y organización

Para comenzar a utilizar Authly, debe crear una cuenta de Administrador junto con su organización desde la pantalla de registro (`register.html`), accesible mediante el botón **«No tengo cuenta»** en la pantalla de inicio de sesión. El proceso se desarrolla en tres pasos guiados por un indicador superior:

Paso 1: Ingreso de datos

Complete el formulario presentado en dos columnas con todos los datos obligatorios:

- **Datos personales:** Nombre, apellido, correo electrónico, contraseña y confirmación de contraseña. Puede presionar el ícono del ojo dentro de cada campo de contraseña para visualizar u ocultar los caracteres ingresados.
- **Datos de la organización:** Nombre de la organización y CUIT. El CUIT debe ingresarse con exactamente **11 dígitos numéricos sin guiones**.

Presione **«Continuar»**. El sistema verificará que los formatos sean válidos, que la contraseña cumpla los requisitos de complejidad (mínimo 10 caracteres, una mayúscula, una minúscula, un número y un carácter especial) y que ni el correo electrónico ni el CUIT se encuentren registrados previamente. Si existe algún error, se mostrará en rojo debajo del campo correspondiente.

Paso 2: Verificación por correo electrónico

Authly enviará un código numérico de **6 dígitos** al correo electrónico ingresado. Ingréselo en el campo habilitado y presione **«Verificar»**.

- **Vigencia e intentos:** El código vence a los **10 minutos** y admite hasta **5 intentos** fallidos. Si se agotan los intentos, deberá reiniciar el registro.
- **Reenvío de código:** Si no recibió el correo o el código venció, presione **«Reenviar código»**. Esto invalidará el código anterior y emitirá uno nuevo (sujeto al límite máximo de **3 códigos por hora** para un mismo correo).

Paso 3: Confirmación

Una vez validado el código, Authly crea de forma atómica su cuenta de Administrador y su organización. Presione **«Ingrese a su cuenta»** para dirigirse a la pantalla de inicio de sesión.

5.2. Inicio de sesión, sesión activa y cierre de sesión

Para ingresar al panel de administración (`login.html`):

1. Ingrese su correo electrónico y su contraseña.
2. Presione **«Iniciar sesión»** (o la tecla **Enter**).

Por seguridad, si el correo no existe o la contraseña es incorrecta, el sistema mostrará siempre el mensaje genérico «Credenciales inválidas.» sin revelar cuál de los dos datos falló.

Duración y expiración de sesión: Una vez autenticado, su sesión permanecerá activa durante **8 horas**. Si la sesión vence mientras opera el panel, Authly limpiará automáticamente sus credenciales locales y lo redirigirá al inicio de sesión mostrando el aviso «Su sesión expiró. Inicie sesión de nuevo.».

Cierre de sesión: En cualquier pantalla del panel, puede presionar el botón **«Cerrar sesión»** ubicado en el extremo derecho del encabezado superior para finalizar su sesión de inmediato.

5.3. Recuperación de contraseña del administrador

Si olvidó su contraseña, haga clic en el enlace **«Olvidé mi contraseña»** en la pantalla de login (`recovery.html`) y siga estos tres pasos:

1. **Solicitud de código:** Ingrese el correo electrónico de su cuenta de Administrador y presione **«Enviar código»**. Por motivos de privacidad, el sistema avanzará siempre al paso siguiente mostrando el mensaje «Si el correo corresponde a una cuenta existente, recibirá un código.».
2. **Código y nueva contraseña:** Ingrese el código de 6 dígitos recibido en su correo, escriba su nueva contraseña (distinta de la actual y cumpliendo las reglas de complejidad) y confírmela. Presione **«Cambiar contraseña»**. Si necesita solicitar un nuevo envío, utilice **«Volver a pedir un código»**.
3. **Confirmación:** Al completarse el cambio, presione **«Ir a iniciar sesión»** para acceder con su nueva clave.

5.4. Gestión de aplicaciones y credenciales

Al iniciar sesión, accederá a la pantalla principal **Mis aplicaciones** (`apps.html`), donde se muestra un resumen con el total de aplicaciones y usuarios de la organización, junto con una tabla paginada (de a 10 elementos) que lista el nombre, la descripción, el **Client ID** y la cantidad de usuarios de cada aplicación.

Crear una aplicación

1. Presione el botón **«Crear aplicación»**.
2. En la ventana emergente, ingrese un **Nombre** (obligatorio y único dentro de su organización, sin distinguir mayúsculas ni espacios sobrantes) y una **Descripción** (opcional).
3. Presione **«Guardar»**.
4. Se abrirá el **Panel de Credenciales** mostrando el **Client ID** y el **Client Secret** generados. Utilice los botones **«Copiar»** para resguardarlos y presione **«Entendido, ya lo copié»** para cerrar.

> **Importante sobre el Client Secret**
> El Client Secret se muestra una única vez al crear la aplicación o al regenerarlo. Authly no lo almacena en texto plano y no permite volver a consultarlo. Si lo extravía, deberá regenerarlo desde el detalle de la aplicación.

Consultar detalle, editar y regenerar el Client Secret

Haga clic sobre el nombre de una aplicación en el listado para ingresar a su vista de detalle (`app.html`). Allí podrá realizar las siguientes operaciones:

- **Copiar Client ID:** Presione **«Copiar»** junto al identificador público de la aplicación (también disponible directamente en la tabla principal).
- **Editar aplicación:** Presione el botón **«Editar»** ubicado junto al título para modificar su nombre o descripción.
- **Regenerar secret:** Presione **«Regenerar secret»** y confirme la advertencia. El secreto anterior quedará invalidado de inmediato y se mostrará el nuevo secreto por única vez. Deberá actualizar esta credencial en el Sistema Externo correspondiente.

Eliminar una aplicación

Al final de la vista de detalle de la aplicación se encuentra la sección **Acciones irreversibles**:

1. Presione **«Eliminar aplicación»**.
2. **Control previo de usuarios:** Si la aplicación tiene usuarios asignados, el sistema bloqueará el borrado e indicará cuántos usuarios deben eliminarse previamente desde la pestaña **«Usuarios»**.
3. **Confirmación reforzada:** Si la aplicación no tiene usuarios, se abrirá un cuadro de confirmación advirtiendo que se eliminarán también todos sus roles y permisos, y que sus credenciales dejarán de funcionar. Escriba el nombre exacto de la aplicación para habilitar el botón de confirmación y presione **«Eliminar aplicación»**.

5.5. Gestión de roles y permisos

Dentro del detalle de una aplicación (`app.html`), seleccione la pestaña **«Roles»**. La tabla lista los roles existentes con su nombre, descripción, etiqueta **Predeterminado** (si corresponde), pares de permisos asignados y cantidad de usuarios que poseen cada rol.

Crear o editar un rol

1. Presione **«Crear rol»** (o **«Editar»** en la fila de un rol existente).
2. Complete el **Nombre** del rol (obligatorio y único dentro de la aplicación) y una **Descripción** (opcional).
3. **Definir permisos:** Presione **«Agregar permiso»** para añadir filas con los campos **Recurso** y **Acción** (ambos obligatorios, por ejemplo: recurso `facturas`, acción `leer`). Puede agregar tantos pares como necesite, quitarlos con el botón **«×»** o dejar la lista vacía si desea un rol sin permisos. No se admiten pares repetidos dentro de un mismo rol.
4. **Rol por defecto:** Marque la casilla **«Rol por defecto»** si desea que todo usuario nuevo registrado vía API reciba este rol automáticamente. Solo puede existir un rol por defecto por aplicación: si marca otro, el sistema transferirá la marca automáticamente e informará cuál era el rol predeterminado anterior.
5. Presione **«Guardar»**. Si le quita la marca de rol por defecto a un rol que la tenía, el sistema le pedirá confirmación advirtiendo que no podrán registrarse nuevos usuarios hasta designar otro rol predeterminado.

Eliminar un rol

Presione **«Eliminar»** en la fila del rol deseado. Si el rol tiene usuarios asignados, Authly impedirá su eliminación e informará cuántos usuarios lo tienen para que primero les cambie el rol o los elimine. Si no tiene usuarios, confirme la acción en el cuadro de diálogo para borrar el rol y sus permisos.

5.6. Gestión de usuarios de una aplicación

Seleccione la pestaña **«Usuarios»** dentro del detalle de la aplicación. La tabla muestra de forma paginada (10 usuarios por página, ordenados alfabéticamente por apellido y nombre) el nombre completo, correo electrónico, roles asignados y botones de acción.

Editar nombre, apellido y roles de un usuario

1. Presione **«Editar»** en la fila del usuario.
2. En el modal de edición, visualizará el correo electrónico en modo de **solo lectura** (no puede modificarse desde el panel).
3. Modifique el **Nombre** o el **Apellido** (ambos obligatorios) y marque o desmarque las casillas de los **Roles** asignados. Todo usuario debe conservar **al menos un rol activo**.
4. Presione **«Guardar»**. Los tres datos se actualizan en una única operación atómica y los permisos efectivos del usuario pasan a ser la suma de los permisos de todos sus roles.

Eliminar un usuario

1. Presione **«Eliminar»** en la fila del usuario.
2. Revise la ficha de confirmación (nombre, correo y roles actuales) y presione **«Eliminar usuario»**.
3. El usuario quedará borrado de forma irreversible de esa aplicación y su dirección de correo quedará libre para un eventual registro futuro.

5.7. Funciones transversales de la interfaz

- **Selector de tema claro y oscuro:** En la esquina superior derecha de todas las pantallas encontrará un botón con ícono de luna/sol que permite alternar entre modo claro y modo oscuro. Su preferencia se guarda automáticamente en el navegador.
- **Visualización de contraseñas:** Todos los campos de clave incorporan un botón con ícono de ojo a la derecha para verificar lo escrito antes de enviar un formulario.
- **Adaptación a dispositivos móviles:** En pantallas angostas (menores a 640 px), el encabezado se reorganiza en dos filas, los botones de formulario se apilan al ancho completo y las tablas de aplicaciones, roles y usuarios se transforman automáticamente en tarjetas individuales con sus respectivos rótulos.

5.8. Operaciones vía API para Sistemas Externos (referencia rápida)

Los sistemas consumidores integran sus backends contra la API REST de Authly utilizando HTTPS y enviando sus credenciales (**Client ID** y **Client Secret**) en cada solicitud protegida:

Caso	Operación API	Descripción operativa
AU-CU-05	Registrar usuario en una aplicación	Envía datos del usuario (email, contraseña, nombre, apellido), verifica el correo mediante código de 6 dígitos y crea la cuenta asignándole el rol por defecto de la aplicación.
AU-CU-07	Autenticar usuario de aplicación	Valida las credenciales de la aplicación y del usuario, y emite un token JWT de acceso (válido por 8 horas) que identifica al usuario y a su aplicación.
AU-CU-08	Obtener clave pública de validación	Endpoint público que entrega la clave pública vigente en formato PEM para que el Sistema Externo verifique localmente la firma de los tokens.
AU-CU-09	Verificar permiso de un usuario	Recibe credenciales de la app, token del usuario, identificador del usuario y par `recurso + acción`. Authly valida firma, vigencia y pertenencia del token y responde si el usuario posee el permiso.
AU-CU-11	Recuperar contraseña de usuario	Inicia y confirma el restablecimiento de clave de un usuario final mediante envío de código de 6 dígitos al correo registrado en esa aplicación.

6. Anexo o apéndice

Anexo A. Mapa de navegación de pantallas del Panel Web

La siguiente tabla resume las pantallas que componen el panel de administración, si requieren sesión activa y hacia dónde navega cada acción principal:

Pantalla / Archivo	Requiere sesión	Flujo y destinos de navegación
Inicio (`index.html`)	No	Redirige automáticamente a `apps.html` si existe una sesión guardada, o a `login.html` en caso contrario.
Login (`login.html`)	No	Al autenticarse va a `apps.html`. Enlaces secundarios hacia `register.html` («No tengo cuenta») y `recovery.html` («Olvidé mi contraseña»).
Registro (`register.html`)	No	Flujo en 3 pasos (Datos → Código → Confirmación). Al finalizar o al presionar «Ya tengo cuenta», navega a `login.html`.
Recuperación (`recovery.html`)	No	Flujo en 3 pasos (Correo → Código y contraseña → Confirmación). Al finalizar o cancelar, regresa a `login.html`.
Mis aplicaciones (`apps.html`)	Sí	Lista paginada de aplicaciones y modal de creación. Al hacer clic en una aplicación navega a `app.html?id=<clientId>`.
Detalle de aplicación (`app.html`)	Sí	Muestra credenciales, edición, eliminación y pestañas **«Roles»** y **«Usuarios»**. El logo o «Volver» regresan a `apps.html`.

Anexo B. Glosario de términos clave

Término	Definición en Authly
Client ID	Identificador público (UUID) generado por Authly para cada aplicación. Se muestra de forma permanente en el panel y debe enviarse en las peticiones de API.
Client Secret	Clave privada de autenticación de una aplicación. Se almacena cifrada (hasheada) y se exhibe una única vez al crear la aplicación o regenerar la credencial.
JWT (JSON Web Token)	Token firmado asimétricamente por Authly que acredita la identidad de un Administrador o de un Usuario final durante 8 horas. No contiene permisos embebidos.
Permiso (Recurso + Acción)	Par de textos libres normalizados en minúsculas (por ejemplo, `reportes` + `exportar`) que define una operación autorizable dentro de un rol.
Rol por defecto (Predeterminado)	Rol único por aplicación que se asigna automáticamente a todo usuario nuevo registrado vía API. Se recomienda configurarlo con privilegios mínimos.

Anexo C. Tabla resumen de reglas de validación y límites operativos

Elemento / Regla	Criterio aplicado en el sistema
Contraseña (AURN-01)	Mínimo 10 caracteres, con al menos 1 mayúscula, 1 minúscula, 1 número y 1 carácter especial. En recuperación debe ser distinta de la contraseña actual.
Correo electrónico (AURN-02)	Insensible a mayúsculas/minúsculas y espacios en los extremos. Único entre administradores y único dentro de cada aplicación.
CUIT (AURN-03)	Exactamente 11 dígitos numéricos, ingresado sin guiones en el formulario web y único en toda la plataforma.
Nombres y permisos (AURN-03)	Comparación insensible a mayúsculas y espacios sobrantes. Los nombres de aplicación son únicos por organización; los nombres de rol son únicos por aplicación. Recursos y acciones se guardan en minúsculas.
Códigos de verificación (AURN-04)	6 dígitos numéricos, vigencia de 10 minutos, máximo 5 intentos por código y límite de emisión de 3 códigos por hora para un mismo correo y propósito.
Sesiones y paginación (AURN-06)	Duración fija de tokens de 8 horas sin renovación automática. Listados paginados de a 10 registros por página en aplicaciones y usuarios.